Corrective Action Tracker (W10)

Findings report — Self-identified

Findings from the Compliance 1 audit (F-01..F-06), the access reviews, the end-to-end tests and the board audit, each tracked to verification. Severities come from the Compliance 1 remediation tracker; others are unrated.

Reference	CAN-FA-001
Domain	Care Access Navigator - IAM & GRC
Status	In progress
Authors	akchrao@gmail.com
Reviewers	-
Date	04/11/2026

Generated at 2026-11-04 18:03:24 UTC
Document ID 4aa7e255-685c-46c5-9650-0d40334b2b22

Summary

Total	Open	Closed	Unresolved important
19	11	8	2

Severity



Findings

High (4)

CA-01 — CA-01 MFA not enforced

Resolved

Owner akchrao@gmail.com
Priority -
ETA / Due - — 2026-11-06

Source: F-01. MFA not enforced

Observation: Owner role: IAM Analyst. Register status: Verified. Verification criterion: Privileged sign-in shows the OTP step. Verification evidence: EV-13: test.billing2 billing-app MFA_REQUIRED. Verified on 2026-11-03.

Recommendation: Bind browser-mfa-privileged realm-wide with role condition mfa-required

Applied controls: Privileged and cardholder-data users pass MFA

Evidences: E-AC-02 - Authentication settings before remediation (Compliance 1 audit), EV-04 - Entra ID to Keycloak connection point (baseline 2026-09-21), EV-02 - Entra ID tenant overview p1 (baseline 2026-09-21), EV-07 - Keycloak sign-in before authentication changes (baseline 2026-09-22), EV-13b - Hardening audit log incl. app-gate verification, EV-03 - Entra ID tenant overview p2 (baseline 2026-09-21), EV-10 - Keycloak MFA authentication flow (baseline 2026-09-22, before W5 hardening)

CA-02 — CA-02 Lockout disabled

Resolved

Owner akchrao@gmail.com
Priority -
ETA / Due - — 2026-10-23

Source: F-02. Lockout disabled

Observation: Owner role: IAM Analyst. Register status: Verified (late). Verification criterion: 11 wrong passwords lock the account. Verification evidence: EV-13 VERIFY.lockout PASS. Verified on 2026-11-03.

Recommendation: bruteForceProtected on, 10 failures, 30 minutes

Applied controls: Lockout after repeated failures; strong password standard

Evidences: EV-09 - Keycloak brute-force detection (baseline 2026-09-22, before W5 hardening), EV-13b - Hardening audit log incl. app-gate verification, EV-08 - Keycloak password policy (baseline 2026-09-22, before W5 hardening), EXPORT - Realm export before hardening (rollback point)

CA-03 — CA-03 No 12-month log retention

Assigned

Owner akchrao@gmail.com
Priority -
ETA / Due - — 2027-01-31

Source: F-03. No 12-month log retention

Observation: Owner role: Security Officer. Register status: Open (EX-02). Verification criterion: Logs older than 90 days can be queried.

Recommendation: Archive identity and cloud logs to low-cost storage with a 365-day lifecycle rule (cost approval needed first)

Applied controls: Security logs are kept 12 months

CAN-FIND-001 — Keycloak Account Deprovisioning Gap

In progress

Owner akchrao@gmail.com
Priority -
ETA / Due - — -

Incomplete automated user deprovisioning between Microsoft Entra ID and Keycloak within the Care Access Navigator healthcare IAM environment.

During Jeevan Smith's termination (TERM-2026-0301), the Entra ID account was disabled, but the corresponding federated Keycloak account remained enabled until manual deactivation.

This gap may create a risk of retained access following employee termination and requires corrective action.

Observation: On October 19, 2026, Jeevan Smith's Entra ID account was disabled at 18:13 UTC, sessions were revoked at 18:15 UTC, and the Billing application assignment was removed at 18:17 UTC.

At 18:25 UTC, testing showed that the corresponding Keycloak account was still enabled. It was subsequently disabled manually at approximately 18:28 UTC.

No active Keycloak sessions or unauthorized EHR access were observed during the test.

The existing manual deprovisioning procedure requires improvement to prevent delays and reduce reliance on administrator intervention.

[Update 2026-11-03] Scripted leaver step verified (TC-04, TC-09 after CA-09); Entra-triggered automatic disable still open - see CAN-CTRL-JML-002.

Recommendation: Implement automated or scheduled-reconciliation-based Keycloak deprovisioning triggered by workforce termination in Microsoft Entra ID.

Include account disablement, Keycloak session termination, account-state verification, and alerting for accounts that remain enabled after termination.

Retest the Joiner-Mover-Leaver workflow and retain evidence demonstrating that terminated users cannot access protected applications.

Track remediation under CAN-CTRL-JML-002 and risk scenario R02.

Applied controls: Automated Keycloak Leaver Deprovisioning

Evidences: Jeevan Smith -Leaver Access Revocation Evidence

Medium (2)

CA-04 — CA-04 Password standard below PCI

Resolved

Owner	akchrao@gmail.com
Priority	-
ETA / Due	- — 2026-10-23

Source: F-04. Password standard below PCI

Observation: Owner role: IAM Analyst. Register status: Verified (late). Verification criterion: 11-character and reused passwords rejected. Verification evidence: EV-13 VERIFY.password_policy. Verified on 2026-11-03.

Recommendation: length(12), history 4

Applied controls: Lockout after repeated failures; strong password standard

Evidences: EV-09 - Keycloak brute-force detection (baseline 2026-09-22, before W5 hardening), EV-13b - Hardening audit log incl. app-gate verification, EV-08 - Keycloak password policy (baseline 2026-09-22, before W5 hardening), EXPORT - Realm export before hardening (rollback point)

CA-05 — CA-05 No completed access review

In progress

Owner	akchrao@gmail.com
Priority	-
ETA / Due	- — 2026-12-15

Source: F-05. No completed access review

Observation: Owner role: IAM Analyst + managers. Register status: In progress. Verification criterion: Every row has reviewer_decision, reviewer, date. Verification evidence: access_review_AR-AFTER-HARDEN-20261103.csv (decisions pending).

Recommendation: Run review; reviewer records a decision per account and signs

Applied controls: Access is reviewed periodically and findings are remediated

Low (1)

CA-06 — CA-06 IdP over HTTP

Assigned

Owner	akchrao@gmail.com

Priority -
ETA / Due - — 2027-01-31

Source: F-06. IdP over HTTP

Observation: Owner role: IT Support. Register status: Open (EX-05). Verification criterion: Sign-in page served over HTTPS with TLS 1.2+.

Recommendation: Put Keycloak behind a TLS reverse proxy

Applied controls: ePHI and credentials are encrypted in transit (TLS 1.2+)

Undefined (12)

CA-07 — CA-07 Vendor added to Billing without a ticket

Resolved

Owner akchrao@gmail.com
Priority -
ETA / Due - — 2026-11-03

Source: TC-07. Vendor added to Billing without a ticket

Observation: Owner role: IAM Analyst. Register status: Verified. Verification criterion: Vendor holds only the vendor role. Verification evidence: EV-14 E2E.remediation TC-07. Verified on 2026-11-03.

Recommendation: Remove the membership; investigate who made it

Applied controls: Privileged access is approved, limited and monitored

Evidences: EV-14 - End-to-end test report TC-01..TC-10 (10/10 PASS, 2026-11-03), PAM - Privileged access matrix

CA-08 — CA-08 test.vendor1 has no sponsor or end date

Assigned

Owner akchrao@gmail.com
Priority -
ETA / Due - — 2026-11-10

Source: Access review. test.vendor1 has no sponsor or end date

Observation: Owner role: IT Manager (sponsor). Register status: Open. Verification criterion: Review shows no VENDOR_NO_END_DATE.

Recommendation: Sponsor sets an end date or the account is removed with the leaver step

Applied controls: Vendor access is sponsored, time-boxed and removed at expiry

CA-09 — CA-09 Leaver (Jeevan Smith) kept the billing role on the disabled Keycloak copy

Resolved

Owner akchrao@gmail.com
Priority -
ETA / Due - — 2026-11-03

Source: TC-09. Leaver (Jeevan Smith) kept the billing role on the disabled Keycloak copy

Observation: Owner role: IAM Analyst. Register status: Verified. Verification criterion: Re-review shows no DISABLED_BUT_HAS_ACCESS. Verification evidence: EV-14 AR-E2E-TC09-AFTER. Verified on 2026-11-03.

Recommendation: Remove the role under TERM-2026-0301; add the IdP-role check to the leaver procedure

Applied controls: Terminated users are disabled and all access removed promptly

Evidences: EV-05 - Federated user confirmation (baseline 2026-09-21), EV-04 - Entra ID to Keycloak connection point (baseline 2026-09-21), JML-15 - Entra ID audit log export for the JML cycle, JML-LOG - Joiner/mover/leaver log (Entra + Keycloak), EV-14 - End-to-end run results (TC-04, TC-09), EV-14 - End-to-end test report TC-01..TC-10 (10/10 PASS, 2026-11-03), Jeevan Smith -Leaver Access Revocation Evidence

CA-10 — CA-10 Brute-force rule CAN-ID-001 alerted only once per user, ever

Resolved

Owner akchrao@gmail.com
Priority -
ETA / Due - — 2026-11-03

Source: TC-05. Brute-force rule CAN-ID-001 alerted only once per user, ever

Observation: Owner role: Security Analyst. Register status: Verified. Verification criterion: A new burst on the same user raises a new alert. Verification evidence: EV-14 TC-05 retest. Verified on 2026-11-03.

Recommendation: Alert once per 10-minute burst

Applied controls: Alerts are raised and investigated

Evidences: EV-14 - Identity detections (CAN-ID rules), IR1-T2 - IR 1 Task 2 log analysis package, EV-14 - End-to-end test report TC-01..TC-10 (10/10 PASS, 2026-11-03)

CA-11 — CA-11 Keycloak port 8080 published on all interfaces

Resolved

Owner akchrao@gmail.com
Priority -
ETA / Due - — 2026-11-10

Source: EX-03. Keycloak port 8080 published on all interfaces

Observation: Owner role: IT Support. Register status: Verified. Verification criterion: Port not reachable from another host. Verification evidence: EV-13 audit log CA-11.applied; LAN-IP request refused; app checks still pass. Verified on 2026-11-04.

Recommendation: Publish as 127.0.0.1:8080 in docker-compose (and pin the compose project name so the existing database volume is kept)

Applied controls: Privileged access is approved, limited and monitored

Evidences: EV-14 - End-to-end test report TC-01..TC-10 (10/10 PASS, 2026-11-03), PAM - Privileged access matrix

CA-12 — CA-12 Lab passwords exposed in public git history

Assigned

Owner akchrao@gmail.com
Priority -
ETA / Due - — 2026-11-10

Source: EX-07. Lab passwords exposed in public git history

Observation: Owner role: IAM Analyst. Register status: Open. Verification criterion: Old password rejected.

Recommendation: Rotate Keycloak admin and database passwords

Applied controls: Lockout after repeated failures; strong password standard

CA-13 — CA-13 Privileged users not yet enrolled in OTP

In progress

Owner akchrao@gmail.com
Priority -
ETA / Due - — 2026-11-10

Source: Access review. Privileged users not yet enrolled in OTP

Observation: Owner role: IAM Analyst. Register status: In progress. Verification criterion: Review shows mfa_enrolled = True for all privileged users.

Recommendation: Enrolment forced at next sign-in; follow up on accounts not enrolled within 7 days

Applied controls: Privileged and cardholder-data users pass MFA

CA-14 — CA-14 Status deck and design doc overstate progress (MVP deck slides 3 and 10; design doc section 14)

Resolved

Owner akchrao@gmail.com
Priority -
ETA / Due - — 2026-11-04

Source: Board audit. Status deck and design doc overstate progress (MVP deck slides 3 and 10; design doc section 14)

Observation: Owner role: Student. Register status: Verified. Verification criterion: Every claim traces to evidence. Verification evidence: MVP deck v1.1 (slides 3, 10); design doc v1.3 section 14 (PDF export of the deck still to do). Verified on 2026-11-04.

Recommendation: Update both to the verified status

Applied controls: Control gaps are tracked to verified remediation

Evidences: CTL-CAT - Control catalog and HIPAA/NIST/ISO/PCI mapping (W9), EV-14 - End-to-end test report TC-01..TC-10 (10/10 PASS, 2026-11-03), CAT - Exceptions and corrective-action tracker

CA-15 — CA-15 PKCE not enforced on public clients

Assigned

Owner akchrao@gmail.com
Priority -
ETA / Due - — 2026-12-15

Source: SV-01..04. PKCE not enforced on public clients

Observation: Owner role: IAM Analyst. Register status: Open. Verification criterion: Sign-in without code_challenge fails.

Recommendation: Set pkce.code.challenge.method = S256

Applied controls: Each application admits only approved job roles

CA-16 — CA-16 Automation signs in as the human admin

Assigned

Owner akchrao@gmail.com
Priority -
ETA / Due - — 2027-01-31

Source: SV-05. Automation signs in as the human admin

Observation: Owner role: IAM Analyst. Register status: Open. Verification criterion: can_iam.py runs with client credentials.

Recommendation: Create a service-account client with only the realm-management roles can_iam.py needs

Applied controls: Privileged access is approved, limited and monitored

CA-17 — CA-17 Entra broker client secret expiry unknown

Assigned

Owner akchrao@gmail.com
Priority -
ETA / Due - — 2026-11-10

Source: SV-06. Entra broker client secret expiry unknown

Observation: Owner role: IAM Analyst. Register status: Open. Verification criterion: Expiry recorded in the register.

Recommendation: Record the expiry and set a reminder 30 days before

Applied controls: Privileged access is approved, limited and monitored

CA-18 — CA-18 IT-Support can sign in to hr-app although its role description excludes HR data

Assigned

Owner akchrao@gmail.com
Priority -
ETA / Due - — 2026-12-15

Source: LP-01. IT-Support can sign in to hr-app although its role description excludes HR data

Observation: Owner role: HR Manager + IAM Analyst. Register status: Open. Verification criterion: Role description and hr-app gate agree.

Recommendation: Owner decides: narrow IT-Support to account administration, or document the business reason

Applied controls: Users receive only the access their job requires (RBAC, least privilege)